

Security+ 2.5 · Mitigation Techniques

Mestre CyberSec — Guia Completo CompTIA Security+ (SY0-701) · **Aula 2.5 — Mitigation Techniques (6:51)**

· [Vídeo Oficial no YouTube ↗](#) · [Página no Professor Messer ↗](#)

Resumo Executivo da Aula: Técnicas de mitigação em CAMADAS: patching (a base mais esquecida); encryption (proteção do dado); monitoring/EDR (observar + responder); least privilege (menor acesso); backup (recovery); training (treinar o humano); compensating control (quando o ideal não dá).

Highlights que a prova cobra

- Patching: a defesa básica mais esquecida (a maioria dos breach era patch conhecida)
- Least privilege: cada pessoa só o mínimo
- Defesa em camadas: nunca 1 solução — empilha

Dicas de prova & Cenários Típicos

- 'reduces impact but doesn't eliminate vulnerability' = compensating control

Cenário clássico de exame: Cenário: 'sistema industrial não pode ter patch; empresa isola e monitora de perto' = compensating control.

Além do Vídeo: O que a CompTIA cobra na prova (Conceitos, Siglas e Armadilhas da Aula 2.5 — Mitigation Techniques)

Por que este aprofundamento é cobrado no exame? O vídeo do Professor Messer apresenta uma introdução ágil. Porém, a banca oficial CompTIA Security+ (SY0-701) exige raciocínio de engenharia prática e cobra diretamente os seguintes protocolos, jargões e ferramentas no contexto desta aula:

- **Princípio do Menor Privilégio:** Usuários e sistemas devem ter apenas as permissões estritamente necessárias para suas funções corporativas.
- **Defesa em Profundidade (Defense-in-Depth):** Aplicação de múltiplas camadas de controles (técnicos, administrativos, físicos) para evitar que a falha de um exponha todo o ambiente.

Armadilhas e Pegadinhas Clássicas da Banca:

- Nunca decore apenas letras ou siglas: a CompTIA altera o cenário exigindo que você justifique por que o controle escolhido é o *MAIS adequado* dentre 4 opções válidas.
- Fique atento às restrições do enunciado: 'sem custo adicional' favorece configurações nativas do SO; 'maior granularidade de rede' favorece TACACS+ em vez de RADIUS; 'não-repúdio' exige chave privada/assinatura digital.

Perguntas de treino comentadas (10 questões)

Gabarito com resolução passo a passo e análise técnica individual de cada distrator no fim. Tente responder antes de olhar.

1. Dar a cada usuário SÓ o acesso mínimo que ele precisa pra função é:

- A) Menor privilégio
- B) Separação de funções
- C) Rotação de cargo
- D) Need-to-know geográfico

2. O framework NIST CSF organiza a segurança em 5 funções. Quais são?

- A) Instalar, Atualizar, Testar, Auditar, Arquivar
- B) Identificar, Proteger, Detectar, Responder, Recuperar
- C) Planejar, Fazer, Checar, Agir, Revisar
- D) Prevenir, Punir, Prever, Provar, Publicar

3. Contratar um seguro cibernético pra cobrir prejuízo de um ataque é qual resposta a risco?

- A)** Aceitar o risco
- B)** Evitar o risco
- C)** Transferir o risco
- D)** Mitigar o risco

4. Cenário corporativo (Mitigation Techniques): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 2.5), um analista avalia o seguinte requisito técnico: 'Patching: a defesa básica mais esquecida (a maioria dos breach era patch conhecida)'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Substituir controles técnicos preventivos por termos de adesão informais
- C)** Implementar a solução correspondente: Patching: a defesa básica mais esquecida (a maioria dos breach era patch co...
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

5. Cenário corporativo (Mitigation Techniques): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 2.5), um analista avalia o seguinte requisito técnico: 'Least privilege: cada pessoa só o mínimo'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Substituir controles técnicos preventivos por termos de adesão informais
- C)** Permitir acesso compartilhado entre administradores com credenciais genéricas
- D)** Implementar a solução correspondente: Least privilege: cada pessoa só o mínimo...

6. Cenário corporativo (Mitigation Techniques): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 2.5), um analista avalia o seguinte requisito técnico: 'Defesa em camadas: nunca 1 solução — empilha'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Substituir controles técnicos preventivos por termos de adesão informais
- C)** Permitir acesso compartilhado entre administradores com credenciais genéricas
- D)** Implementar a solução correspondente: Defesa em camadas: nunca 1 solução — empilha...

7. Cenário corporativo (Mitigation Techniques): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 2.5), um analista avalia o seguinte requisito técnico: 'reduces impact but doesn't eliminate vulnerability' = compensating control'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Implementar a solução correspondente: 'reduces impact but doesn't eliminate vulnerability' = compensating control...
- C)** Substituir controles técnicos preventivos por termos de adesão informais
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

8. Cenário corporativo (Mitigation Techniques): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 2.5), um analista avalia o seguinte requisito técnico: 'Cenário: 'sistema industrial não pode ter patch; empresa isola e monitora de perto' = compensating control.'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Substituir controles técnicos preventivos por termos de adesão informais
- C)** Permitir acesso compartilhado entre administradores com credenciais genéricas
- D)** Implementar a solução correspondente: Cenário: 'sistema industrial não pode ter patch; empresa isola e monitora d...

9. Cenário corporativo (Mitigation Techniques): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 2.5), um analista avalia o seguinte requisito técnico: 'Patching: a defesa básica mais esquecida (a maioria dos breach era patch conhecida)'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Substituir controles técnicos preventivos por termos de adesão informais
- C)** Permitir acesso compartilhado entre administradores com credenciais genéricas
- D)** Implementar a solução correspondente: Patching: a defesa básica mais esquecida (a maioria dos breach era patch co...

10. Cenário corporativo (Mitigation Techniques): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 2.5), um analista avalia o seguinte requisito técnico: 'Least privilege: cada pessoa só o mínimo'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Implementar a solução correspondente: Least privilege: cada pessoa só o mínimo...
- C)** Substituir controles técnicos preventivos por termos de adesão informais
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

GABARITO COMENTADO COM ANÁLISE DETALHADA DOS DISTRATORES

1) A — Menor privilégio.

✓ **Por que está certa:** A alternativa correta é 'Menor privilégio'. O princípio do menor privilégio (least privilege) determina que cada usuário, processo ou sistema deve receber apenas as permissões estritamente necessárias para executar suas funções, e nada além disso. No contexto de segurança da informação, isso reduz a superfície de ataque e limita o impacto de um comprometimento. Por exemplo, um usuário do departamento financeiro não deve ter acesso a arquivos de recursos humanos. O CompTIA Security+ SY0-701, no domínio de Arquitetura e Design (2.1), lista o menor privilégio como um princípio fundamental de segurança. A questão descreve exatamente essa definição: dar a cada usuário só o acesso mínimo que ele precisa para a função.

✗ **Por que as outras estão erradas:**

- *Separação de funções:* Separação de funções (separation of duties) é um controle que divide uma tarefa crítica em etapas executadas por pessoas diferentes, de modo que nenhuma pessoa tenha controle total sobre o processo. Por exemplo, quem aprova um pagamento não pode ser o mesmo que o executa. Isso evita fraudes e erros, mas não se refere a conceder o mínimo de acesso por usuário; em vez disso, distribui responsabilidades. A questão fala de acesso mínimo individual, não de divisão de tarefas.
- *Rotação de cargo:* Rotação de cargo (job rotation) é uma prática de mover funcionários periodicamente entre diferentes funções para detectar fraudes, reduzir monotonia e treinar pessoal. Não tem relação com o princípio de conceder apenas o acesso necessário. Rotação de cargo é uma estratégia de mitigação de riscos internos, mas não define o nível de privilégio de cada usuário.
- *Need-to-know geográfico:* Need-to-know é um princípio de segurança que restringe o acesso à informação apenas a quem precisa dela para realizar uma tarefa específica. No entanto, 'need-to-know geográfico' não é um termo padrão na certificação CompTIA Security+. O conceito de need-to-know é frequentemente associado ao menor privilégio, mas a expressão 'geográfico' adiciona uma restrição de localização que não está presente na definição clássica. A questão não menciona restrição geográfica, apenas acesso mínimo funcional. Portanto, a alternativa é imprecisa e não corresponde ao termo técnico correto.

2) B — Identificar, Proteger, Detectar, Responder, Recuperar.

✓ **Por que está certa:** O NIST Cybersecurity Framework (CSF) 2.0 organiza as atividades de segurança cibernética em cinco funções principais: Identificar, Proteger, Detectar, Responder e Recuperar. Essas funções representam o ciclo de vida completo da gestão de riscos cibernéticos. 'Identificar' envolve entender o contexto organizacional, ativos, riscos e vulnerabilidades. 'Proteger' abrange a implementação de salvaguardas para garantir a entrega de serviços críticos. 'Detectar' define as atividades para identificar a ocorrência de eventos de segurança cibernética. 'Responder' compreende as ações tomadas após a detecção de um incidente. 'Recuperar' foca na restauração de capacidades ou serviços que foram prejudicados. Essa estrutura é amplamente adotada e exigida no domínio de Arquitetura e Design de Segurança da certificação CompTIA Security+ (SY0-701), especificamente no objetivo 2.1, que trata de frameworks e diretrizes.

✗ **Por que as outras estão erradas:**

- *Instalar, Atualizar, Testar, Auditar, Arquivar:* Esses termos descrevem etapas genéricas de um processo operacional de TI, como um ciclo de vida de software ou de gestão de patches, mas não constituem as funções do NIST CSF. 'Instalar' e 'Atualizar' referem-se à implantação e manutenção de sistemas; 'Testar' é uma atividade de verificação; 'Auditar' é uma avaliação de conformidade; e

'Arquivar' é uma prática de retenção de dados. Nenhuma dessas ações corresponde às funções estratégicas de alto nível definidas pelo NIST CSF, que são orientadas a riscos e não a tarefas táticas.

- *Planejar, Fazer, Checar, Agir, Revisar*: Essa é uma variação do ciclo PDCA (Plan-Do-Check-Act), utilizado em sistemas de gestão da qualidade e melhoria contínua, como a ISO 9001. Embora o NIST CSF possa ser integrado a processos de melhoria contínua, suas cinco funções não são 'Planejar, Fazer, Checar, Agir, Revisar'. O PDCA é um modelo genérico de gestão, enquanto as funções do CSF são específicas para segurança cibernética e possuem escopo e definições próprias. A inclusão de 'Revisar' como quinta etapa é uma distorção, pois o PDCA clássico tem quatro etapas.

- *Prevenir, Punir, Prever, Provar, Publicar*: Esses termos não fazem parte de nenhum framework reconhecido de segurança cibernética. 'Prevenir' é um objetivo, mas não uma função do CSF; 'Punir' é uma ação disciplinar ou legal, não uma função de segurança; 'Prever' é uma meta aspiracional, não uma função operacional; 'Provar' e 'Publicar' são ações de auditoria e comunicação, respectivamente, mas não compõem a estrutura do NIST CSF. Essa alternativa mistura conceitos de justiça, previsão e divulgação, sem qualquer relação com as funções oficiais do framework.

3) C — Transferir o risco.

✓ **Por que está certa:** A alternativa correta é: Transferir o risco. No domínio de Gestão de Riscos da CompTIA Security+ SY0-701, as respostas ao risco incluem evitar, mitigar, transferir e aceitar. A transferência de risco ocorre quando a organização repassa a responsabilidade financeira por um risco a terceiros, tipicamente por meio de seguros cibernéticos, contratos de outsourcing ou cláusulas de indenização. Ao contratar um seguro cibernético, a empresa paga um prêmio para que a seguradora cubra prejuízos decorrentes de ataques, como custos de recuperação, multas regulatórias, extorsão e responsabilidade civil. É importante notar que a transferência não elimina o risco em si (o ataque ainda pode ocorrer), mas transfere o impacto financeiro. A organização ainda deve manter controles de segurança para gerenciar a probabilidade e o impacto residual.

✗ **Por que as outras estão erradas:**

- *Aceitar o risco*: Aceitar o risco significa reconhecer a existência de um risco e decidir não tomar nenhuma ação para mitigá-lo ou transferi-lo, geralmente porque o custo da mitigação excede o benefício ou porque o risco é considerado aceitável dentro do apetite da organização. Contratar um seguro não é aceitar o risco, pois envolve uma ação ativa de transferência financeira. A aceitação é passiva e não envolve terceiros.
- *Evitar o risco*: Evitar o risco significa eliminar a atividade ou o processo que gera o risco. Por exemplo, desativar um serviço vulnerável ou proibir o uso de dispositivos USB. Contratar um seguro não evita o risco; a atividade continua existindo e o ataque ainda pode ocorrer. A evitação é uma mudança de comportamento para eliminar a exposição, enquanto o seguro lida com as consequências financeiras.
- *Mitigar o risco*: Mitigar o risco significa implementar controles para reduzir a probabilidade ou o impacto de um incidente. Exemplos incluem firewalls, criptografia, treinamento de conscientização e backups. Contratar um seguro não reduz a probabilidade de um ataque nem o impacto técnico; ele apenas compensa financeiramente as perdas. Portanto, não é uma medida de mitigação, mas de transferência.

4) C — Implementar a solução correspondente: Patching: a defesa básica mais esquecida (a maioria dos breach era patch co....

✓ **Por que está certa:** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 2.5 (Mitigation Techniques): Patching: a defesa básica mais esquecida (a maioria dos breach era patch conhecida).

✗ Por que as outras estão erradas:

- *Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema:* Viola frontalmente o pilar de Accounting e a rastreabilidade forense. Sem logs, a equipe fica cega para detectar incidentes e quebra normas de conformidade (PCI DSS, ISO 27001).
- *Substituir controles técnicos preventivos por termos de adesão informais:* Termos informais são controles administrativos, dependem exclusivamente da conduta do usuário e não bloqueiam ataques automatizados, injeções ou malwares em tempo de execução.
- *Permitir acesso compartilhado entre administradores com credenciais genéricas:* Destrói a responsabilização individual (Accountability) e o Não-repúdio. Torna impossível comprovar quem realizou alterações críticas ou comandos maliciosos.

5) D — Implementar a solução correspondente: Least privilege: cada pessoa só o mínimo....

✓ **Por que está certa:** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 2.5 (Mitigation Techniques): Least privilege: cada pessoa só o mínimo.

✗ Por que as outras estão erradas:

- *Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema:* Viola frontalmente o pilar de Accounting e a rastreabilidade forense. Sem logs, a equipe fica cega para detectar incidentes e quebra normas de conformidade (PCI DSS, ISO 27001).
- *Substituir controles técnicos preventivos por termos de adesão informais:* Termos informais são controles administrativos, dependem exclusivamente da conduta do usuário e não bloqueiam ataques automatizados, injeções ou malwares em tempo de execução.
- *Permitir acesso compartilhado entre administradores com credenciais genéricas:* Destrói a responsabilização individual (Accountability) e o Não-repúdio. Torna impossível comprovar quem realizou alterações críticas ou comandos maliciosos.

6) D — Implementar a solução correspondente: Defesa em camadas: nunca 1 solução — empilha....

✓ **Por que está certa:** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 2.5 (Mitigation Techniques): Defesa em camadas: nunca 1 solução — empilha.

✗ Por que as outras estão erradas:

- *Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema:* Viola frontalmente o pilar de Accounting e a rastreabilidade forense. Sem logs, a equipe fica cega para detectar incidentes e quebra normas de conformidade (PCI DSS, ISO 27001).
- *Substituir controles técnicos preventivos por termos de adesão informais:* Termos informais são controles administrativos, dependem exclusivamente da conduta do usuário e não bloqueiam ataques automatizados, injeções ou malwares em tempo de execução.
- *Permitir acesso compartilhado entre administradores com credenciais genéricas:* Destrói a responsabilização individual (Accountability) e o Não-repúdio. Torna impossível comprovar quem realizou alterações críticas ou comandos maliciosos.

7) B — Implementar a solução correspondente: 'reduces impact but doesn't eliminate vulnerability' = compensating control....

✓ **Por que está certa:** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 2.5 (Mitigation Techniques): 'reduces impact but doesn't eliminate vulnerability' = compensating control.

✗ Por que as outras estão erradas:

- *Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema:* Viola

frontalmente o pilar de Accounting e a rastreabilidade forense. Sem logs, a equipe fica cega para detectar incidentes e quebra normas de conformidade (PCI DSS, ISO 27001).

- *Substituir controles técnicos preventivos por termos de adesão informais*: Termos informais são controles administrativos, dependem exclusivamente da conduta do usuário e não bloqueiam ataques automatizados, injeções ou malwares em tempo de execução.
- *Permitir acesso compartilhado entre administradores com credenciais genéricas*: Destrói a responsabilização individual (Accountability) e o Não-repúdio. Torna impossível comprovar quem realizou alterações críticas ou comandos maliciosos.

8) D — Implementar a solução correspondente: Cenário: 'sistema industrial não pode ter patch; empresa isola e monitora d....

✓ **Por que está certa:** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 2.5 (Mitigation Techniques): Cenário: 'sistema industrial não pode ter patch; empresa isola e monitora de perto' = compensating control..

✗ **Por que as outras estão erradas:**

- *Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema*: Viola frontalmente o pilar de Accounting e a rastreabilidade forense. Sem logs, a equipe fica cega para detectar incidentes e quebra normas de conformidade (PCI DSS, ISO 27001).
- *Substituir controles técnicos preventivos por termos de adesão informais*: Termos informais são controles administrativos, dependem exclusivamente da conduta do usuário e não bloqueiam ataques automatizados, injeções ou malwares em tempo de execução.
- *Permitir acesso compartilhado entre administradores com credenciais genéricas*: Destrói a responsabilização individual (Accountability) e o Não-repúdio. Torna impossível comprovar quem realizou alterações críticas ou comandos maliciosos.

9) D — Implementar a solução correspondente: Patching: a defesa básica mais esquecida (a maioria dos breach era patch co....

✓ **Por que está certa:** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 2.5 (Mitigation Techniques): Patching: a defesa básica mais esquecida (a maioria dos breach era patch conhecida).

✗ **Por que as outras estão erradas:**

- *Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema*: Viola frontalmente o pilar de Accounting e a rastreabilidade forense. Sem logs, a equipe fica cega para detectar incidentes e quebra normas de conformidade (PCI DSS, ISO 27001).
- *Substituir controles técnicos preventivos por termos de adesão informais*: Termos informais são controles administrativos, dependem exclusivamente da conduta do usuário e não bloqueiam ataques automatizados, injeções ou malwares em tempo de execução.
- *Permitir acesso compartilhado entre administradores com credenciais genéricas*: Destrói a responsabilização individual (Accountability) e o Não-repúdio. Torna impossível comprovar quem realizou alterações críticas ou comandos maliciosos.

10) B — Implementar a solução correspondente: Least privilege: cada pessoa só o mínimo....

✓ **Por que está certa:** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 2.5 (Mitigation Techniques): Least privilege: cada pessoa só o mínimo.

✗ **Por que as outras estão erradas:**

- *Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema*: Viola frontalmente o pilar de Accounting e a rastreabilidade forense. Sem logs, a equipe fica cega para detectar incidentes e quebra normas de conformidade (PCI DSS, ISO 27001).

- *Substituir controles técnicos preventivos por termos de adesão informais*: Termos informais são controles administrativos, dependem exclusivamente da conduta do usuário e não bloqueiam ataques automatizados, injeções ou malwares em tempo de execução.
- *Permitir acesso compartilhado entre administradores com credenciais genéricas*: Destroi a responsabilização individual (Accountability) e o Não-repúdio. Torna impossível comprovar quem realizou alterações críticas ou comandos maliciosos.